



Implementing Decentralized Digital Technical Product Documentation

CRA meets Machinery Regulation

Merzough Munker mmuenker@enduradocs.de

Software engineer · Co-Founder of EnduraDocs GmbH · Member of the iiRDS Consortium

Who is speaking

Merzough Munker

- Software engineer with a background in web and cloud application development
- Co-founder of EnduraDocs in Aachen, where he leads engineering
- Works on the iiRDS standard as a member of the iiRDS Consortium

Intention of the talk

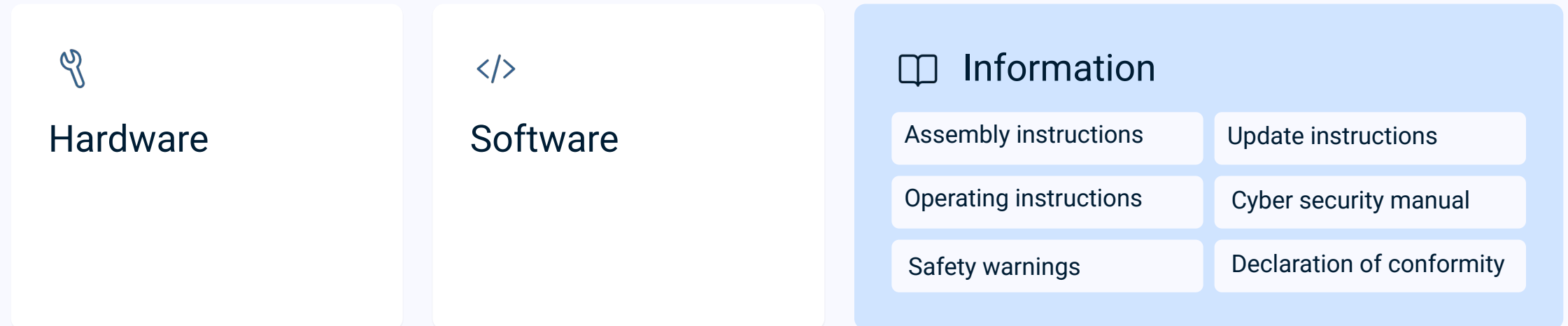
- We see it this way
- We built it this way for machinery
- We believe it can be adapted for products with digital elements

Where are we wrong? What are we missing?

Two regulations, one structure

Obligation	Machinery Regulation (EU) 2023/1230	CRA (EU) 2024/2847
Identification	Art. 10(5): model, series or type, year, serial	Art. 13(15): type, batch or serial number
Manufacturer and single point of contact	Art. 10(6)	Art. 13(16)–(17), Annex II (1)–(2). Adds: SPOC for vulnerability reporting, where the CVD policy is
Instructions, paper or digital	Art. 10(7): online "during the expected lifetime and for at least 10 years"	Art. 13(18), Annex II: "10 years or the support period, whichever is longer" Annex II (8) allows an internet address
Declaration of conformity by URL or machine-readable code	Art. 10(8)	Art. 13(20), Annex II (6)
Risk assessment	EN ISO 12100: residual risks go into the instructions	Art. 13(2)–(3): cybersecurity risk assessment

Documentation is part of the product



An error in the information is an error in the product.

Placing-on-the-market law, product safety and product liability apply. A contract cannot override them. In machinery, the warnings in the manual are the causal output of the risk assessment: the residual risks design could not remove.

A point in time vs. a support period

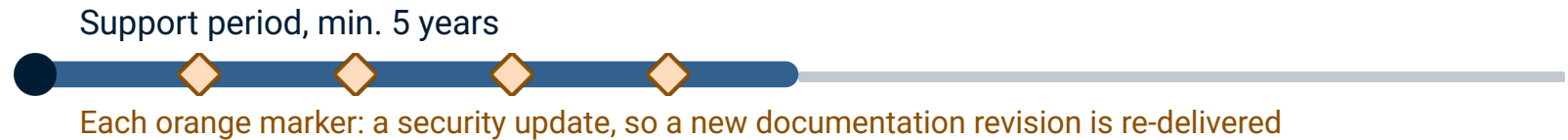
MACHINERY REGULATION

Checked once



CYBER RESILIENCE ACT

Kept up to date



Placing on the market

+5 years

+10 years online

Documentation stops being a deliverable and becomes part of the delivery pipeline.

PDF alone will not be sufficient.

Physical and digital supply chains

Physical



Digital



Same position, different form: a library is integrated like a bought-in part, and its licence sits where the supply contract sits.

Art. 25

Voluntary security attestation for FOSS

Art. 13(6)

Report vulnerabilities upstream

Art. 13(5)

Due diligence on integrated components, incl. FOSS

Annex II (8)(f)

Information for integrators

Given that the requirements are structurally the same,
this is how we implement them for machinery.
Adaptation to products with digital elements works partially.

Next: metadata · distribution · storage · automation

Anatomy of an iiRDS package

Claim: Annex II and MR Art. 10 items fit standard RDF metadata. No custom schema.

product.iirds (ZIP)

META-INF/metadata.rdf

RDF 1.1 XML: products, parties, document types, versions

content renditions

PDF, HTML, media

nested .iirds

A component supplier's own package

Open standard (iiRDS Consortium) for machine-readable user information. [An exchange format](#), not a storage or display format.

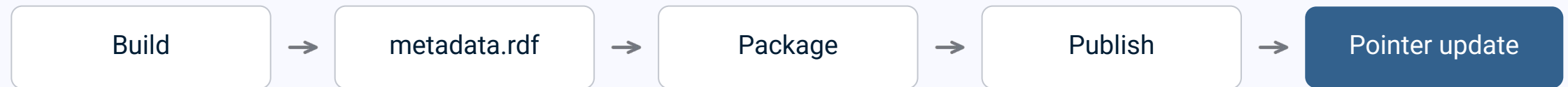
```
<iirds:Document rdf:about=".../csm/en/2">
  <iirds:revision>2</iirds:revision>
  <iirds:is-version-of
    rdf:resource=".../io/csm"/>
  <iirds:relates-to-party><iirds:Party>
    <iirds:has-party-role
      rdf:resource="...#Manufacturer"/>
    <iirds:relates-to-vcard>
      <vcard:Organization>
        <vcard:fn>Example Machines</vcard:fn>
        <vcard:hasEmail rdf:resource="mailto:..." />
      </vcard:Organization>
    </iirds:relates-to-vcard>
  </iirds:Party>
</iirds:Document>
```

Annex II, item by item, in iiRDS

CRA Annex II item	iiRDS expression
(1) Manufacturer name, (e-mail) address	iirds:Party + vCard, iirds:PartyRole; accountable per component
(2) Single point of contact, CVD policy	Designated iirds:Party with role; CVD policy as a typed information unit
(3) Unique product identification	iirds:ProductVariant, iirds:Component; iirds:Identity
(4)–(5), (8)(a)–(e) purpose, security, setup, updates, decommissioning	Typed iirds:Topic / iirds:Document (DocumentType); the cyber security manual is one more typed document
(6) Internet address of the DoC	Rendition or external reference with its own IRI
(7) End date of the support period	Product-level metadata; see also Art. 13(19)
(8)(f) Integrator information	Nested iiRDS packages from component suppliers
(9) Where the SBOM can be accessed	Open question
Versions over the support period	iirds:InformationObject + iirds:is-version-of; each revision a new unit, stable IRI

Documentation as part of package publishing pipeline

Annex I Part II (4) and (8) require advisories and update information with every security update.



The Annex I Part II (8) advisory is one more typed information unit in the revision. Unchanged content is not copied.

iiRDS Request API

A specified REST interface: query by product, component, version, language, document type. No knowledge of the producer's system needed.

Our implementation

Stateless, AGPLv3, self-hostable. Anyone in the chain can run it in front of the same archives, even if the manufacturer ceases operations (Art. 13(23)).

IPFS asks what, not where

LOCATION ADDRESSING · HTTP

```
https://vendor.com/manual.pdf
```

Points to a server. Breaks when the server, domain or path goes away. The file can change silently.

CONTENT ADDRESSING · IPFS

```
/ipfs/bafy...<CID>
```

The CID is a hash of the bytes. Any node that has them can serve them, and anyone can verify them.

Peer-to-peer

Any node can store and serve content; gateways bridge to HTTP.

Pinning

A node keeps content available by pinning it; unpinned data can be dropped.

Mutable names

A CID never changes, so DNSLink maps a domain to the latest CID.

Durability as a property of the data

"At least 10 years" should not depend on a vendor's infrastructure, ours included.



Pinned on our own IPFS cluster, on the customer's node, reachable through any gateway.

CID = integrity check

Same bytes anywhere, verifiable by anyone.

Revisions never change

A new revision is a new CID; the pointer moves.

History stays

Old revisions retrievable: Art. 13(9), 13(11).

Replication and ownership is one command

```
docker run ... ipfs pin add <CID>
```

Repoint DNS

To any gateway or your own

MR Art. 10(7)(b): users must be able to print, download and save the instructions "so that he or she can access them at all times".

Public IPFS is world-readable

TODAY

Anyone with the CID can read it. Restricted content is protected only at the perimeter: proxy + IdP.

MOVING TO

Each file encrypted with OpenTDF and decrypted on the reader's device, so the key server never sees the content.

Work in progress, not a solved problem

What we measured breaking

- ⚠️ Revocation semantics
- ⚠️ No range reads on encrypted PDFs
- ⚠️ Integrity checks in the container format

A thin adapter, and it should stay thin

An MCP server exposing the iIRDS Request API as tools, with OAuth2 against the same IdP:

find product

list information units

fetch rendition

resolve version

DESIGN PRINCIPLE

No processing

It does not parse, summarize or transform content. It speaks the Request API and returns structured assets with metadata and provenance intact.

The answer stays traceable: **iirds:Party, document type, revision, CID**. Security operations pull the advisory, update instructions and SBOM location for the exact component version they run: Annex I Part II (4), (8).

IN ONE SENTENCE

Two regulations,
one information model,
one delivery chain.

Where are we wrong? What are we missing?

Merzough Munker

mmuenker@enduradocs.de

enduradocs.de

iirds.org

Where do the SBOM and the SPOC belong?

SBOM: inside the package, linked by IRI, or kept outside?

As a CycloneDX / SPDX rendition, a link, or only a reference (Annex I Part II (1), Annex II (9)). Not decided; the Commission may specify the format by implementing act, Art. 13(24).

Is iirds:Party + vCard enough for the SPOC and CVD obligation?

Or does the WG see a need for a dedicated vocabulary?

How often, and who gets in?

Should every security update produce a documentation revision?

Security updates may be weekly or daily, CBOM changes every few months. Or only when user-relevant information changes? Who decides, and how is that decision auditable?

Machine-to-machine access across the supply chain

We use OAuth2 today. Does the WG have a preferred pattern for restricted documentation?

Evidence and access

Is content addressing acceptable evidence for market surveillance?

"This is the document that was published on date X." Does anyone know of precedent?

Is encryption on a public network compatible with Art. 13(18)?

"Accessible, user-friendly and available online", or does restricted documentation belong on a different transport?

Where is the boundary?

Is "no processing" the right boundary?

Or is there legitimate processing, e.g. SBOM/CBOM diffing across revisions, that should sit in the adapter?

Provenance of AI-mediated answers

Is metadata pass-through enough, or should responses carry a signed reference to the source information unit?

5 · OPEN QUESTIONS OVERVIEW

- Where do the SBOM and the SP0C belong?
- How often, and who gets in?
- Evidence and access?
- Where is the boundary?